

Informe de Auditoría de Seguridad

Sistema Analizado: Localhost

Fecha de generación: 2026-02-07 18:05:44

Versión del motor: 1.0

Clasificación: CONFIDENCIAL

Auditoría automatizada · Red Team · Hardening · CIS Benchmark

Índice

1. Resumen de la Auditoría
2. Hallazgos
3. Remediaciones Detalladas
4. Playbooks de Seguridad
5. Conclusión Técnica

Resumen de la Auditoría

Este informe resume los hallazgos detectados durante el análisis automatizado de seguridad.

Severidad	Recuento
Crítica	0
Alta	3
Media	2
Baja	0
Info	0
Total	5

Las secciones posteriores detallan los hallazgos, su impacto técnico, indicadores asociados y recomendaciones completas de remediación.

Hallazgos

CHK-SSH-5 — SSH Banner no configurado

Referencia CIS: 5.1.5

Severidad: MEDIA

Explicación breve:

Un banner legal advierte sobre uso no autorizado.

Evidencia:

No se encontró parámetro Banner

Recomendación:

Añadir Banner /etc/issue.net

CHK-SSH-6 — Ciphers inseguros detectados

Referencia CIS: 5.1.6

Severidad: ALTA

Explicación breve:

Los cifrados CBC son débiles frente a ataques conocidos.

Evidencia:

```
Se encontró el cipher inseguro: aes128-cbc
```

Recomendación:

```
Ciphers aes256-ctr,aes192-ctr,aes128-ctr
```

CHK-SSH-8 — AllowTcpForwarding debe estar en 'no'

Referencia CIS: 5.1.8

Severidad: ALTA

Explicación breve:

Evita tunelización no autorizada.

Evidencia:

```
Línea 126: AllowTcpForwarding yes
```

Recomendación:

```
AllowTcpForwarding no
```

CHK-SSH-22 — UsePAM debe estar en 'yes'

Referencia CIS: 5.1.22

Severidad: MEDIA

Explicación breve:

PAM añade controles avanzados de autenticación.

Evidencia:

```
Línea 147: UsePAM no
```

Recomendación:

```
UsePAM yes
```

CHK-SSH-12 — KexAlgorithms inseguros detectados

Referencia CIS: 5.1.12

Severidad: ALTA

Explicación breve:

Usar Algoritmos Kex inseguros puedes exponer las conexiones a posibles ataques 'Man In The Middle'

Evidencia:

```
Se encontró el KexAlgorithm inseguro: diffie-hellman-group1-sha1
```

Recomendación:

```
KexAlgorithms ecdh-sha2-nistp256,ecdh-sha2-nistp384,ecdh-sha2-nistp521,diffie-hellman-group-exchange-sha256,diffie-hellman-group16-sha512,diffie-hellman-group18-sha512,diffie-hellman-group14-sha256
```

Remediaciones Detalladas

Esta sección proporciona instrucciones extensas y completas para corregir cada hallazgo, incluyendo impacto técnico, pasos detallados y validaciones posteriores.

CHK-SSH-5 — SSH Banner no configurado

Impacto técnico:

Un banner legal advierte sobre uso no autorizado.

Pasos de remediación:

1. Editar o crear el banner:
`sudo nano /etc/issue.net`
2. Añadir texto legal corporativo.
3. Configurar SSH para usarlo:
`sudo nano /etc/ssh/sshd_config`
`Banner /etc/issue.net`
4. Recargar SSH:
`sudo systemctl restart sshd`

Validación posterior:

```
sshd -T | grep banner --> Debe aparecer: banner /etc/issue.net
```

CHK-SSH-6 — Ciphers inseguros detectados

Impacto técnico:

Los cifrados CBC son débiles frente a ataques conocidos.

Pasos de remediación:

1. Editar archivo SSH:
`sudo nano /etc/ssh/sshd_config`
2. Localizar:
se encontró el cipher inseguro: aes128-cbc
3. Aplicar la recomendación:
`Ciphers aes256-ctr,aes192-ctr,aes128-ctr`
4. Recargar SSH:
`sudo systemctl restart sshd`

Validación posterior:

```
sshd -T | grep ciphers --> Debe aparecer: Ciphers aes256-ctr,aes192-ctr,aes128-ctr
```

CHK-SSH-8 — AllowTcpForwarding debe estar en 'no'

Impacto técnico:

Evita tunelización no autorizada.

Pasos de remediación:

1. Editar archivo SSH:
`sudo nano /etc/ssh/sshd_config`
2. Localizar:
línea 126: `allowtcpforwarding yes`
3. Aplicar la recomendación:
`AllowTcpForwarding no`
4. Recargar SSH:
`sudo systemctl restart sshd`

Validación posterior:

```
sshd -T | grep allowtcpforwarding --> Debe aparecer: AllowTcpForwarding no
```

CHK-SSH-22 — UsePAM debe estar en 'yes'

Impacto técnico:

PAM añade controles avanzados de autenticación.

Pasos de remediación:

1. Editar archivo SSH:
`sudo nano /etc/ssh/sshd_config`
2. Localizar:
línea 147: `usepam no`
3. Aplicar la recomendación:
`UsePAM yes`
4. Recargar SSH:
`sudo systemctl restart sshd`

Validación posterior:

```
sshd -T | grep usepam --> Debe aparecer: UsePAM yes
```

CHK-SSH-12 — KexAlgorithms inseguros detectados

Impacto técnico:

Usar Algoritmos Kex inseguros puedes exponer las conexiones a posibles ataques 'Man In The Middle'

Pasos de remediación:

1. Revisar evidencia:
se encontró el kexalgorithm inseguro: diffie-hellman-group1-sha1
2. Aplicar la recomendación:
KexAlgorithms ecdh-sha2-nistp256,ecdh-sha2-nistp384,ecdh-sha2-nistp521,diffie-hellman-group-exchange-sha256,diffie-hellman-group16-sha512,diffie-hellman-group18-sha512,diffie-hellman-group14-sha256

Validación posterior:

Validación manual requerida. --> Debe verificarse que el servicio funcione y el cambio está aplicado.

Playbooks de Seguridad

Esta sección presenta escenarios de explotación y defensa basados en los hallazgos detectados. Los playbooks están contruidos usando tácticas MITRE ATT&CK, Kill Chain y técnicas de Red Team.

Playbook SSH

Táctica: Initial Access
Técnica: T1110 – Password Brute Force

1. Descubrimiento de servicio:
nmap -p 22 Localhost
2. Ataque de fuerza bruta:
hydra -l root -P rockyou.txt ssh://Localhost
3. Pivoting si AllowTcpForwarding = yes:
ssh -L 3306:localhost:3306 user@Localhost
4. Persistencia:
echo "clave_maliciosa" >> ~/.ssh/authorized_keys

Playbook Firewall (UFW)

Escenario: Puerto crítico expuesto

1. Detección:
nmap -sV -p 3306,6379,27017 Localhost
2. Explotación:
Conectar al servicio expuesto con credenciales débiles.
3. Elevación:
Explotar service misconfigurations.
4. Defensa:
ufw deny 3306

Conclusión Técnica

El análisis realizado ha permitido identificar configuraciones inseguras, servicios expuestos y parámetros críticos que requieren remediación prioritaria. La combinación de hallazgos indica un riesgo operativo significativo si no se implementan las acciones de mitigación proporcionadas.

Se recomienda priorizar las remediaciones de severidad **Crítica y Alta**, ya que representan rutas directas de compromiso del sistema. Una vez implementadas las correcciones, puede ejecutarse un nuevo análisis para verificar la efectividad del endurecimiento.

Este informe proporciona una base sólida para el hardening continuo del entorno, permitiendo avanzar hacia un sistema alineado con CIS Benchmark y mejores prácticas de la industria.